

Nome: Martina Foresta

Corso: CyberSecurity

Attività: Regola firewall pfSense per bloccare DVWA da Kali Linux

Blocco dell'accesso a DVWA con pfSense

Il compito richiedeva di bloccare, tramite pfSense, l'accesso da Kali Linux a DVWA su Metasploitable e di documentare la differenza tra una scansione prima e dopo il blocco. Un requisito era collocare Kali e Metasploitable su reti diverse. Ho quindi preparato il percorso attraverso il firewall prima di creare la regola.

1 La separazione delle reti del laboratorio

All'inizio Kali e Metasploitable erano entrambe sulla rete interna intnet, rispettivamente con gli indirizzi 192.168.50.100 e 192.168.50.101. I ping funzionavano, ma questo non bastava per l'esercizio: due macchine sulla stessa rete possono comunicare direttamente senza passare dal firewall.

pfSense disponeva già di una scheda WAN in modalità bridge e di una LAN sulla rete interna intnet. Ho aggiunto una terza scheda collegata a una seconda rete interna, intnet2, e ho spostato su questa rete la scheda di Metasploitable. Kali è rimasta su intnet.

Macchina o interfaccia	Indirizzo durante la prova	Collegamento
Kali Linux	192.168.50.100/24	intnet
pfSense LAN	192.168.50.1/24	intnet
pfSense LAN2	192.168.51.1/24	intnet2
Metasploitable	192.168.51.101/24	intnet2
pfSense WAN	192.168.1.10	Bridge

Interfaces				
	WAN	↑	1000baseT <full-duplex>	192.168.1.10 2a09:e6c7:f800:113d:a00:27ff:fe12:de2e
	LAN	↑	1000baseT <full-duplex>	192.168.50.1
	LAN2	↑	1000baseT <full-duplex>	192.168.51.1

Con questa disposizione, Kali raggiunge Metasploitable attraverso pfSense. La separazione delle reti rende quindi possibile applicare una regola al traffico tra le due macchine.

2 L'attivazione di LAN2 e il nuovo indirizzo di Metasploitable

Dopo aver avviato pfSense ho aperto la sua interfaccia web da Kali all'indirizzo 192.168.50.1. In Interfaces, Assignments ho aggiunto la porta em2, inizialmente disponibile tra le interfacce non assegnate. Ho aperto OPT1, abilitato l'interfaccia e assegnato il nome LAN2.

Ho selezionato Static IPv4 e impostato 192.168.51.1/24 e salvato e applicato la configurazione.

Interfaces / OPT1 (em2)

General Configuration

Enable ☒ Enable interface

Description
Enter a description (name) for the interface here.

IPv4 Configuration Type

IPv6 Configuration Type

MAC Address
This field can be used to modify ("spoof") the MAC address of this interface.
Enter a MAC address in the following format: xxxxxxxx:xxxx:xxxx or leave blank.

MTU
If this field is blank, the adapter's default MTU will be used. This is typically 1500 bytes but can vary in some circumstances.

MSS
If a value is entered in this field, then MSS clamping for TCP connections to the value entered above minus 40 for IPv4 (TCP/IPv4 header size) and minus 60 for IPv6 (TCP/IPv6 header size) will be in effect.

Speed and Duplex
Explicitly set speed and duplex mode for this interface.
WARNING: MUST be set to autoselect (automatically negotiate speed) unless the port this interface connects to has its speed and duplex forced.

Static IPv4 Configuration

IPv4 Address /

IPv4 Upstream gateway [+ Add a new gateway](#)
If this interface is an Internet connection, select an existing Gateway from the list or add a new one using the "Add" button.
On local area network interfaces the upstream gateway should be "none".
Selecting an upstream gateway causes the firewall to treat this interface as a WAN type interface.
[Gateways can be managed by clicking here](#)

Su Metasploitable ho poi modificato `/etc/network/interfaces`, mantenendo la configurazione di loopback e impostando eth0 con i seguenti valori:

```
auto eth0
iface eth0 inet static
address 192.168.51.101
netmask 255.255.255.0
gateway 192.168.51.1
```

Il gateway corrisponde all'interfaccia LAN2 di pfSense. Serve a inoltrare verso il firewall il traffico destinato alle reti esterne alla sottorete di Metasploitable, compresa la rete di Kali.

3 La verifica della configurazione e dell'accesso iniziale

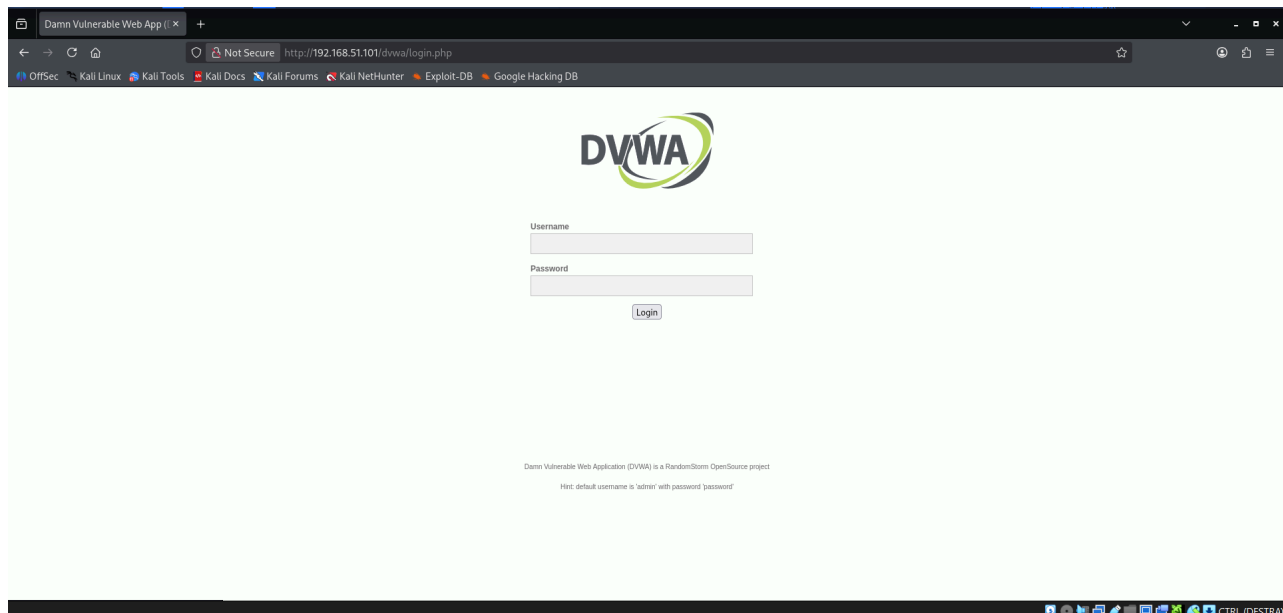
Ho applicato la configurazione con `sudo /etc/init.d/networking restart` e verificato l'indirizzo con `ifconfig eth0`. L'interfaccia risultava attiva con 192.168.51.101 e maschera 255.255.255.0.

```
msfadmin@metasploitable:~$ sudo /etc/init.d/networking restart
* Reconfiguring network interfaces...
SIOCDELRT: No such process
[ OK ]

msfadmin@metasploitable:~$ ifconfig eth0
eth0      Link encap:Ethernet  HWaddr 08:00:27:25:91:4c
          inet addr:192.168.51.101  Bcast:192.168.51.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe25:914c/64  Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1 errors:0 dropped:0 overruns:0 frame:0
          TX packets:100 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:64 (64.0 B)  TX bytes:11324 (11.0 KB)
          Base address:0xd020  Memory:f0200000-f0220000

msfadmin@metasploitable:~$
```

Prima di aggiungere il blocco, da Kali ho aperto <http://192.168.51.101/dvwa/>. Il browser ha visualizzato la pagina di login di DVWA. Questo controllo era importante perché dimostrava che l'applicazione fosse raggiungibile anche dopo la separazione delle reti.



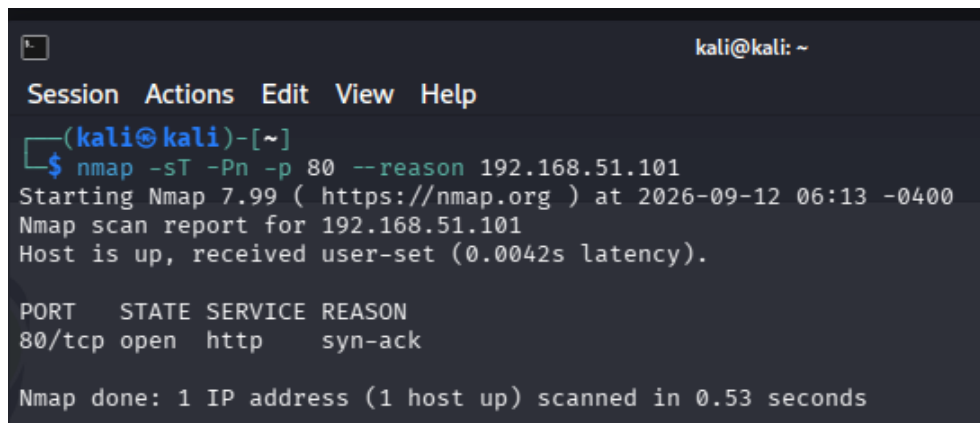
Ho conservato questa schermata come riferimento iniziale: il confronto successivo doveva riguardare l'effetto della regola, senza confonderlo con un problema precedente di indirizzamento o con un servizio già irraggiungibile.

4 La scansione iniziale e i criteri della regola

Nel terminale di Kali ho eseguito una scansione TCP limitata alla porta 80 di Metasploitable:

```
nmap -sT -Pn -p 80 --reason 192.168.51.101
```

L'opzione -sT esegue una connessione TCP, -Pn evita la fase preliminare di individuazione dell'host e -p 80 limita la prova alla porta HTTP. Con --reason ho ottenuto anche il motivo dello stato rilevato. Il risultato era 80/tcp open, con motivo syn-ack: la porta rispondeva alla connessione.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -sT -Pn -p 80 --reason 192.168.51.101  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-12 06:13 -0400  
Nmap scan report for 192.168.51.101  
Host is up, received user-set (0.0042s latency).  
  
PORT      STATE SERVICE REASON  
80/tcp    open  http   syn-ack  
  
Nmap done: 1 IP address (1 host up) scanned in 0.53 seconds
```

In Firewall, Rules ho selezionato LAN, perché è l'interfaccia da cui entra in pfSense il traffico proveniente da Kali. Ho aggiunto una regola con questi criteri:

System
Interfaces
Firewall
Services
VPN
Status
Diagnostics
Help

Firewall / Rules / Edit

Edit Firewall Rule

Action

Block

Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Disabled

☐ Disable this rule

Set this option to disable this rule without removing it from the list.

Interface

LAN

Choose the interface from which packets must come to match this rule.

Address Family

IPv4

Select the Internet Protocol version this rule applies to.

Protocol

TCP

Choose which IP protocol this rule should match.

Source

Source

☐ Invert match

Address or Alias

192.168.50.100

Hide Advanced

The Source Port Range for a connection is typically random and almost never equal to the destination port. In most cases this setting must remain at its default value, any.

Source Port Range

any

From

Custom

To

Specify the source port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Destination

Destination

☐ Invert match

Address or Alias

192.168.51.101

Destination Port Range

HTTP (80)

From

Custom

To

Specify the destination port or port range for this rule. The "To" field may be left empty if only filtering a single port.

Extra Options

Log

☒ Log packets that are handled by this rule

Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the [Status: System Logs: Settings](#) page).

Description

Blocca Kali verso DVWA

A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset and displayed in the firewall log.

Advanced Options

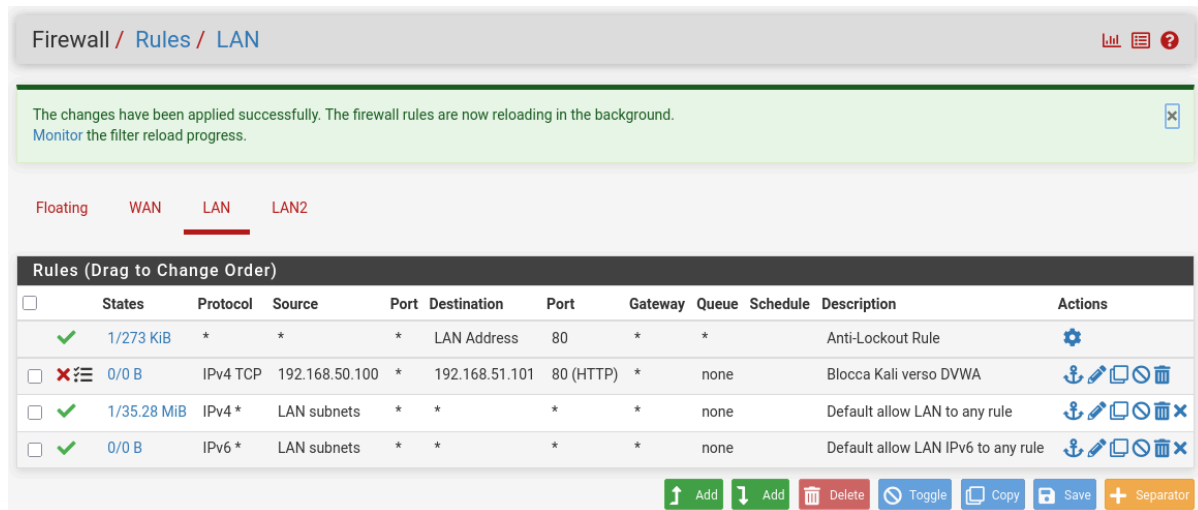
Display Advanced

Save

5

5 L'applicazione del blocco e la nuova scansione

Ho salvato la regola e applicato le modifiche. Nell'elenco LAN l'ho collocata sopra Default allow LAN to any rule: una regola generale di permesso posta prima del blocco avrebbe consentito quel traffico.



Ho ripetuto da Kali lo stesso comando Nmap, sullo stesso indirizzo e sulla stessa porta. Questa volta il risultato è stato 80/tcp filtered con motivo no-response. La scansione veniva ancora eseguita, ma non riceveva la risposta TCP osservata nella prova iniziale.

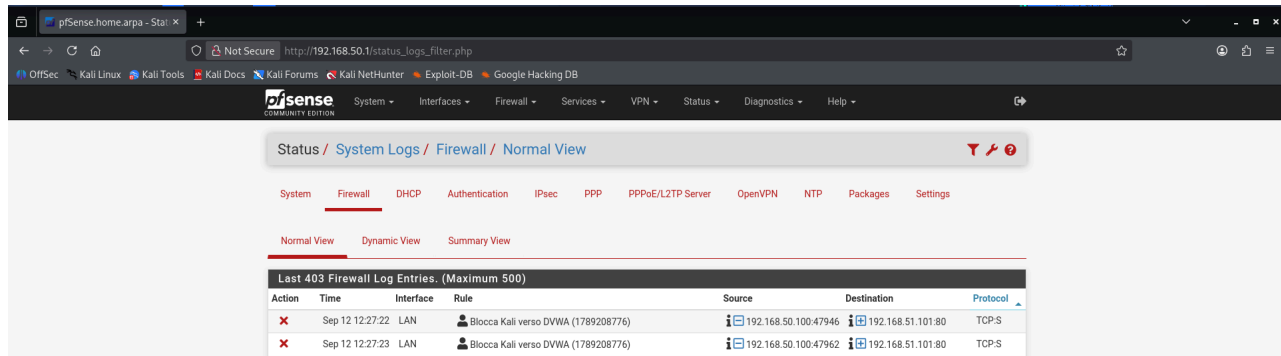
```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nmap -sT -Pn -p 80 --reason 192.168.51.101  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-12 06:27 -0400  
Nmap scan report for 192.168.51.101  
Host is up, received user-set.  
  
PORT      STATE      SERVICE REASON  
80/tcp    filtered  http    no-response  
  
Nmap done: 1 IP address (1 host up) scanned in 2.53 seconds
```

Ho interpretato il risultato come porta filtrata dal percorso di rete, non come servizio spento o porta chiusa.

Il confronto è riferito al traffico TCP sulla porta 80 da Kali a Metasploitable. Non ho esteso il risultato alle altre porte o a tutti i protocolli della macchina.

6 I log del firewall e la verifica dal browser

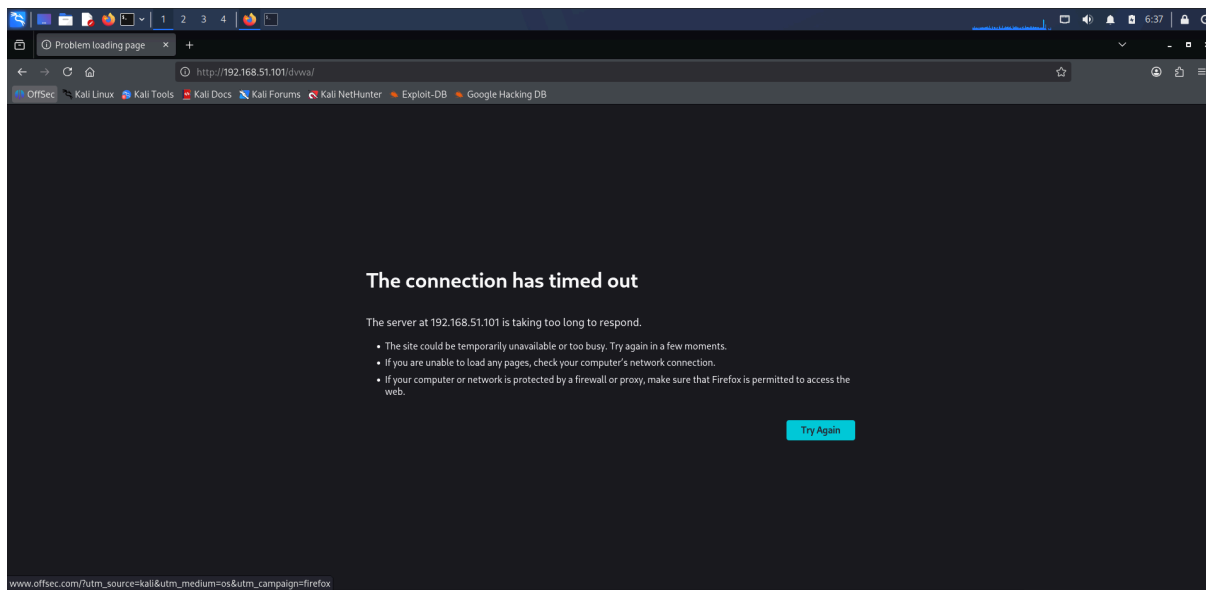
Per verificare che il blocco dipendesse dalla regola creata, ho aperto Status, System Logs, Firewall. Le prime due voci mostravano pacchetti bloccati sull'interfaccia LAN dalla regola Blocca Kali verso DVWA, dalla sorgente 192.168.50.100 alla destinazione 192.168.51.101:80. Il protocollo TCP:S indicava pacchetti TCP con flag SYN.



The screenshot shows the pfSense web interface. The breadcrumb navigation is 'Status / System Logs / Firewall / Normal View'. Below the navigation tabs, there are three tabs: 'Normal View', 'Dynamic View', and 'Summary View'. The 'Normal View' tab is selected, displaying a table of firewall log entries. The table has columns for Action, Time, Interface, Rule, Source, Destination, and Protocol. Two entries are visible, both marked with a red 'X' in the Action column, indicating blocked traffic. The first entry is from 192.168.50.100:47946 to 192.168.51.101:80 via the LAN interface, blocked by the rule 'Blocca Kali verso DVWA (1789208776)' using the TCP-S protocol. The second entry is from 192.168.50.100:47962 to 192.168.51.101:80 via the LAN interface, also blocked by the same rule using the TCP-S protocol.

Action	Time	Interface	Rule	Source	Destination	Protocol
✗	Sep 12 12:27:22	LAN	Blocca Kali verso DVWA (1789208776)	192.168.50.100:47946	192.168.51.101:80	TCP-S
✗	Sep 12 12:27:23	LAN	Blocca Kali verso DVWA (1789208776)	192.168.50.100:47962	192.168.51.101:80	TCP-S

Ho infine tentato di riaprire `http://192.168.51.101/dvwa/` da Kali. Il browser ha restituito un timeout invece della pagina di login. Questa prova ha aggiunto al risultato di Nmap la verifica diretta dell'accesso all'applicazione.



Il passaggio che mi ha chiarito meglio il funzionamento del firewall è stato separare le due reti: avere pfSense acceso non significa che ogni comunicazione lo attraversi. Ho poi potuto collegare i criteri della regola a un effetto preciso, verificato con scansione, log e browser.

La regola blocca la porta HTTP di Metasploitable per Kali, quindi impedisce anche l'accesso a DVWA. Non distingue il percorso `/dvwa/` dagli altri contenuti eventualmente serviti sulla stessa porta. Questa è la portata effettiva del risultato ottenuto nel laboratorio.